INTELLICON'26 BUILDATHON — GATE 1: PROBLEM & PROOF · WRITE-UP

AEGIS (working title)

Autonomous AI security operations for businesses that live online — proving the problem before building the answer.

Team	OneEye360
Members	Sandaru Sathsara Wickramasighe
Category	Cybersecurity — AI Agents & Web Application Defense
Submitted	26 September 2026

01 THE PROBLEM & OUR DOMAIN

In the agentic-AI era, every organization that runs on a website, an app, or a database faces machine-speed attacks it cannot see, cannot afford to test for, and cannot hire enough humans to stop — and in Sri Lanka that danger is growing roughly **5× faster than reported cybercrime did just two years ago**, while enterprise-grade protection remains priced for corporations, not for the millions of businesses that now depend on being online.

Our domain is application-layer cybersecurity — the security of the websites, web applications, APIs, and servers that businesses now run on. Two structural shifts define this domain in 2026. First, attackers have industrialized: a malicious email is launched every **19 seconds**, AI-generated phishing surged **~14×** in a single year, and 76% of organizations admit they cannot match the speed of AI-powered attacks [15][16][17]. Second, defense still runs on scarce, expensive human experts — a model that never scales to millions of small businesses. The result is a protection gap that widens every month, in Sri Lanka and everywhere.

99×
Growth in reported Sri Lankan cybercrime, 2020 → 2025 [1]

19 sec
Cadence of malicious emails in 2025 — 2× faster than 2024 [16]

81%
Of small businesses suffered a breach in the past year [14]

$5K–$50K
Cost of a single manual penetration test [19]

The affordability trap: *enterprise WAF tiers start around $3K–$5K per month and a single manual penetration test costs $5K–$50K [19][20] — for the small businesses and universities that are now the primary targets of AI-accelerated attacks.* **For our segments, protection is not expensive; it is structurally out of reach.**

02 TARGET USER — WHO FEELS IT, AND HOW MANY THEY ARE

We avoid "everyone with a server." We studied three segments where the pain is sharp, frequent, and provable today — starting in Sri Lanka.

PRIMARY SEGMENT · SRI LANKA

Online-dependent SMBs & e-commerce operators

Sri Lanka's digital economy is worth **Rs 1,342 billion (4.5% of GDP)**; e-commerce alone is **Rs 735 billion, growing 10.8% a year**, with **52% of internet users buying online monthly** [7][8]. SMEs are **52% of GDP and over 75% of all enterprises** [9]. Each runs a website, a payment flow, and a customer database — personal data now protected by the PDPA, with penalties enforceable since 18 March 2025 [5].

Why they can't act: 74% self-manage security or rely on untrained family; only 18% have ever used a penetration test. A breach costing under $50,000 would force **55% of SMBs to shut down** [13].

Retail & e-commerce | Hospitality & bookings | Fintech apps | Online services | Healthtech portals

BEACHHEAD SEGMENT · ALREADY UNDER ATTACK

Universities, institutes & education platforms

Sri Lanka's education sector has already been breached repeatedly, at scale: the **Department of Examinations hack exposed ~270,000 students' results data** [3]; the **Ministry of Education website was hacked by an A-Level student** [4]; a **university internship portal breach claim (June 2026) put ~4,490 people's PII at risk** [2]; and a **Sri Lankan university database was advertised for sale on a hacker forum** [2]. They hold thousands of identity records on thin budgets — and must now protect them by law [5].

EXPANSION SEGMENT

Online-first startups & SaaS across emerging markets

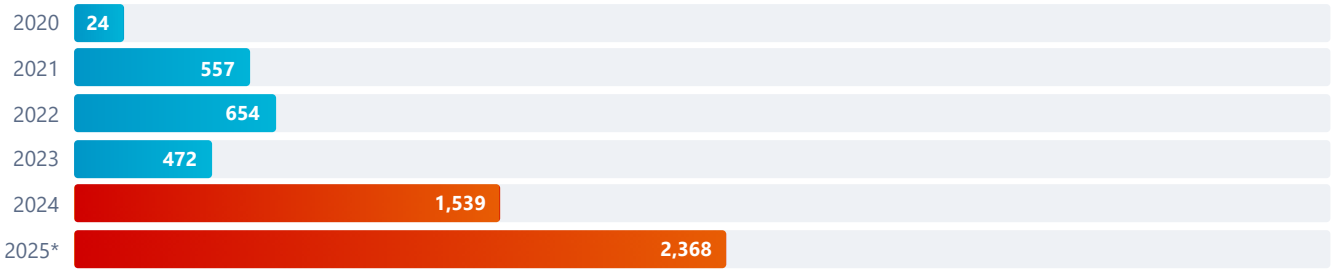
Globally, **81% of small businesses suffered a security or data breach in the past year**, with **AI-powered attacks the root cause in over 40% of incidents** and typical losses of **$250K–$1M** [14]. Emerging markets, where digital adoption outpaces security investment, are the fastest-growing phishing targets [17]. They ship fast, hold customer data, and have no security staff.

Personas we are solving for

Persona	What their week looks like	The moment of pain
"Dinesh" E-commerce founder, Colombo 8 staff, LKR 2M+/mo revenue	Runs the store, marketing, and deliveries himself; site built by a freelancer two years ago, rarely updated.	Discovers leaked customer data or a redirected checkout — too late; no early warning at all.
"Priyantha" IT administrator, private university 1 IT person, 4,000+ student records	Maintains portals, results systems, and internship platforms with legacy code and no security budget.	A dark-web post claims his portal was breached; he cannot prove otherwise — no testing, no monitoring, no logs. PDPA liability is personal [2][5].
"Sanduni" CTO & co-founder, booking SaaS startup 5-person team, cloud-native	Ships features daily; security is a console checklist item she never fully understood.	A customer's security questionnaire demands a recent pentest. The quote: $12,000 and six weeks — lose the deal or skip it [19].

03 VALIDATION — THE PROBLEM IS GENUINE (SRI LANKA GROUND TRUTH)

A. The local curve is vertical. Reported cybercrime in Sri Lanka has multiplied almost **99× in five years**, and the national CERT is absorbing the shock:



Reported cybercrimes per year, Minister of Public Security statement to Parliament, 21 Nov 2025 (2025 = Jan–Oct only). *Reported cases only — the real number is higher. SLCERT separately handled 12,650+ complaints in 2025 [1].

99×
Reported cybercrime growth, 2020 → 2025 (24 → 2,368) [1]

12,650+
Complaints handled by SLCERT in 2025 — a "sharp increase" [1]

~2,000
Cybercrimes reported to police in 2025; 318 arrests [1]

B. It is already happening to institutions exactly like our beachhead

Incident	What happened	Source
Department of Examinations	A student hacked the official website and republished **~270,000 students' 2021 A/L results data**.	[3]
Ministry of Education website	Hacked by an A-Level student who left a note urging them to fix "some security flaws" — found in minutes what no budget had tested for.	[4]
University internship portal (2026)	Dark-web actor claims admin access to a Sri Lankan university's internship system — **~4,490 individuals' PII** potentially exposed.	[2]
University database for sale	A threat actor advertised a Sri Lankan university's database (300+ records incl. student/staff IDs and hashed credentials) on a hacking forum; suspected SQL injection origin.	[2]

> *"My name is Anonymous EEE and I am currently studying A/L. Sorry for unauthorized access to your website but* **your website has some security flaws**. *As a Sri Lankan citizen, I am reporting this for the safety of my country. Fix it, thanks."*
>
> *— message left inside the hacked Ministry of Education website [4]. A student found in minutes what no institution had budget to test for.*

03 VALIDATION — THE PROBLEM IS SEVERE (GLOBAL EVIDENCE)

C. What one successful attack costs. The most widely cited global datasets agree on the scale:

$4.44M
Global average cost of a data breach; **241 days** is the average time to find and contain one [10]

$5.08M
Average cost of a ransomware/extortion incident when disclosed by the attacker [10]

88%
Of SMB breaches involve ransomware — vs 39% for large organizations [11]

1 in 5
SMBs say a single successful attack would close them [13]

Structural force	What the data says	Source
Attackers industrialized	A malicious email every 19 seconds; AI-generated phishing up ~14× in a year to 56% of detected attacks; 16% of breaches already involve attacker AI [10][16][17].	[15][16][17]
Humans are scarce	95% of cyber teams report critical skills gaps; 88% have already suffered a real security incident because of it; a single professional pentest costs $5K–$50K and takes weeks.	[18][19]
Protection is mispriced	Enterprise-grade WAF protection starts around $3K–$5K/month; SMBs are left choosing between basic tiers and nothing at all.	[20][21]

The affordability trap: after an attack, the only widely-trusted responses — a manual penetration test ($5K–$50K, 3–6 weeks) or an enterprise WAF tier (~$3K–$5K+/month) — cost as much as the disaster itself [19][20]. For our segments, **protection is not expensive; it is structurally out of reach.**

D. Sri Lanka's digital growth makes this urgent, not distant. The number of Sri Lankans who transact, study, and sell online is compounding at double digits [7][8], every new business added to that economy inherits the same unprotected attack surface, and since **18 March 2025** the law holds them responsible for the personal data they hold [5]. Exposure is growing exponentially; defenses are not growing at all for anyone below enterprise budgets.

What we have validated — and what comes next

Gate 1 rests on **24 cited public sources** (full claim-by-claim mapping in the companion **Supportive Evidence & Source Index** document), spanning government statements, national CERT data, industry reports (IBM, Verizon, CrowdStrike, ISC2, WEF), Sri Lankan incident records, published vendor pricing, and independent SMB studies. Attacker-claimed incidents are labeled as unverified. Primary validation — **10–15 structured interviews with local business owners, pilot Letters of Intent, and false-positive benchmarks on our own test applications** — is the documented Gate 2 plan (see Tech Stack & Plan).

04 MARKET SIZE — LOCAL FIRST, THEN THE SAME GAP EVERYWHERE

We size the opportunity from both directions — the global category and our Sri Lankan beachhead — because our strategy is to **win Sri Lanka first**, then expand to markets with the identical shape.

$78.6B
Global SMB cybersecurity spend in 2025 → $189.4B by 2034 (10.3%/yr) [27]

$10.6B
Combined global WAF + penetration-testing spend today, growing ~15%/yr [25][26]

Rs 1,342B
Sri Lanka's digital economy (4.5% of GDP); e-commerce Rs 735B [7]

1.0M+
MSME establishments in Sri Lanka — 52% of GDP, >75% of enterprises [9]

Layer	Size & reasoning
TAM Global	SMB cybersecurity is a **$78.6B market in 2025, growing 10.3%/yr to $189.4B by 2034**; 43% of all cyber incidents already target SMBs [27]. Our specific wedge — web-application testing + WAF — is **~$10.6B combined today**: WAF $8.6B growing 14.9%/yr [25]; penetration testing $2.0B growing 14.2%/yr to $4.4B by 2031 [26].
SAM Regional	Asia-Pacific is the fastest-growing region for both categories (~38% of pentest revenue [26]). The highest-need slice is emerging-market SMBs "where digital adoption outpaces security investment" [17] — precisely the South/Southeast Asian profile.
SOM Sri Lanka first	**1.0–1.3M MSME establishments** (52% of GDP, >75% of enterprises) [9]. If even ~5% run meaningful online operations (≈50–65K businesses), a **$20/month service ≈ $12–16M/year in Sri Lanka alone** — our estimate, assumptions stated. Education adds every institution holding student PII under the PDPA [5]. Expansion: replicate across South/Southeast Asian markets with the same gap.

Why the local market is reachable now — not in five years

- **The law arrived:** PDPA fully enforceable since 18 March 2025 — breach notification and penalties make protection a legal necessity, not a nice-to-have; the Cyber Security Act adds a national regulator and an accreditation regime for security providers [5].
- **The demand signal is national:** SLCERT absorbed 12,650+ complaints in 2025; reported cybercrime up ~99× in five years [1].
- **The customer base is compounding:** 13.9M internet users (+12% YoY), 52% buying online monthly, e-services +15.7%/yr [6][7][8].
- **Pricing power is local:** we build for $15–30/month tiers from day one — not an enterprise product discounted down.

05 COMPETITORS — WE MAPPED THE WHOLE SPACE

Before proposing anything, we mapped every realistic option our segments can buy today, and why each one leaves the gap open:

Option	Typical cost	Why the underserved segment still loses
Manual penetration testing firms	$5,000–$50,000 per engagement; enterprise $100K+; 3–6 weeks to report; retests $2K–$8K extra [19]	Point-in-time snapshot — a photo of one day of the year, obsolete at the next code deploy. Priced at 10–100× an SMB's monthly security budget. Manual retests after every change are unaffordable.
PTaaS (pentest-as-a-service)	~31% cheaper than consultancies; still thousands of dollars/yr [19]	Better economics, same human-hours model — still scheduled, still slow, still unaffordable below enterprise scale.
Enterprise WAF layers (Akamai, Imperva, Cloudflare Enterprise, F5)	~$3,000–$5,000/month entry; $30K–$250K/yr at scale [20][21]	Full managed rulesets, ML bot management and analytics sit behind enterprise contracts. Below that tier, SMBs get static rule packs that unique, AI-generated payloads walk past [16].
Cloud WAF basics (AWS WAF, Cloudflare Pro/Business)	$20–$250/month + per-request fees [21]	Affordable but demands 5–10 hrs/month of skilled engineering to configure and maintain — the exact resource our segments do not have. Default rulesets underperform against novel payloads.
Vulnerability scanners (SaaS)	$100–$1,700/month [24]	Scanning ≠ exploitation. They list possible weaknesses with high false positives; they do not verify exploit chains, do not think like an attacker, and flood non-experts with noise they cannot act on.
MSSPs / managed SOC	Ongoing contracts; require scale	Built for mid-market and up; SLA-driven monitoring, not deep testing. Only 15% of SMBs have any internal IT or MSSP support at all [13].
Do nothing / "we're too small to matter"	$0 — until it isn't	60% of SMBs know they are the likeliest targets, yet most still choose this [13]. In Sri Lanka the assumption is disproven by the incidents in Validation — attackers found a university portal and a national exams database worth breaching.

The pattern across the entire space

Everything affordable is shallow

Basic WAF rules, signature scanners, checklist tools. Cheap, but blind to novel, AI-generated attack patterns — and unusable without security expertise.

Everything deep is expensive

Elite human pentesters, enterprise WAF tiers, 24/7 SOCs. Effective, but priced and staffed for the top of the market.

No offering combines depth + continuity + affordability for the segment that is being hit hardest. That empty quadrant is not a product gap we invented — it falls directly out of the pricing evidence and the SMB impact data. It is the gap we commit to for this Buildathon.

06 SOLUTION — OUR WORKING ANSWER (A DIRECTION, NOT YET THE PRODUCT)

Gate 1 proves the question is right. Our working hypothesis — to be tested and torn apart over the next three weeks — is a **low-cost, high-impact autonomous security layer** with two cooperating parts:

1 · Autonomous penetration-testing agents

Multi-agent AI that probes a target web application or server the way a real attacker would: reconnaissance, attack planning, verified exploit chains, real-time tracking of findings, and **actionable fix reports in plain language** — not a raw scanner dump. Continuous and on-demand, not a once-a-year photo.

2 · Affordable AI WAF & continuous monitoring

A continuously monitoring filtering layer powered by **JEV-family AI decision models** — small, typed, calibrated classifiers purpose-built for high-volume, near-real-time security judgments at a fraction of the cost of conventional ML pipelines. Two detection tiers: **recognition of established attack patterns**, plus **anomaly analysis that flags payloads matching no known signature** — the novel, AI-generated attacks static rule packs walk past. Every attempt is logged with attack-type classification into analytics a business owner can actually read — enterprise-grade defense at a price an SMB can budget monthly.

One product, one loop: agents find weaknesses, the shield blocks live attacks, and each feeds the other — verified findings tune the WAF's rules, live attack telemetry steers the next test priorities — while the dashboard shows measurable security posture over time, delivered as a recurring, subscription-based service.

What makes this different from what is already available

vs.	The difference we are building
AI security copilots	Copilots assist enterprise SOC experts at enterprise prices. Ours is **autonomous — no security expert required on the customer side** — and priced for SMB budgets from day one.
Scanners & basic WAF tiers	Scanners list possible weaknesses with high false positives; basic WAF tiers run static rules that AI-generated payloads walk past [16]. Ours **verifies exploit chains** (agent side) and **detects novel, non-signature patterns** (WAF side).
Point-in-time pentesting	Manual engagements snapshot one day of the year at $5K–$50K [19]. Ours runs continuously and on-demand — and each test makes the live shield smarter.

Business model: recurring monthly subscription — target tiers **$15–30/month for SMBs**, institutional pricing for education — with a self-serve dashboard as the primary interface. Feasibility of elite autonomous pentesting is publicly proven [23]; our engineering bet is on **cost-optimized architecture** — tool-first agents, JEV-family decisions, aggressive caching — that makes the economics work at SMB price points: the part the market has not solved.

07 WHY AI — THE ONLY ANSWER THAT CLOSES BOTH GAPS

AI is not a feature of our answer; it is the only realistic answer. Three proofs:

1. **The speed asymmetry is already decisive.** 76% of global organizations struggle to match the speed and sophistication of AI-powered attacks; 89% now call AI-powered protection essential; ~50% fear they cannot respond at machine speed at all [15]. A defense paced by human analysts loses by default.
2. **The human ceiling cannot scale to millions of businesses.** 95% of security teams report skills gaps and 88% have already suffered a real security consequence because of them [18]. There is no hiring path that puts an expert inside 1M+ small businesses — the only scalable defender is software that reasons like an attacker.
3. **Feasibility is publicly proven at elite level.** XBOW — a fully autonomous AI pentester — became the first AI to top HackerOne's US leaderboard, with 1,000+ validated vulnerability reports and a previously-unknown Palo Alto flaw affecting 2,000+ hosts [23]. IBM measures AI-driven defenses cutting global breach costs by ~9%, saving ~$1.9M per breach for extensive users [10].

> **The capability exists; the economics do not.** *Autonomous AI security is proven at elite level and priced for enterprises — while the businesses being hit hardest can afford neither the capability nor the price.*

That is precisely our opening. Our engineering bet is **cost-optimized architecture**: agents orchestrate **pre-defined security tools that do the heavy lifting**, so AI spend stays at routing level, not compute level; **JEV-family AI decision models** handle the WAF's high-volume, near-real-time judgments at a cost per decision conventional ML pipelines cannot match; **strong LLM response caching** and tiered models (cheap models for breadth, frontier reasoning for depth) cap the rest. XBOW proved AI can do the work; nobody has yet engineered it for the budget of a business in Colombo or Kandy. **That is the part we intend to demonstrate.**

Why now, in one line: attacks industrialized with AI [15][16][17], the defender workforce is structurally short [18], autonomous offense is proven [23], AI-assisted defense measurably works [10], and Sri Lanka's PDPA just made protection legally mandatory [5] — every trend line points at the same gap.

08 TECH STACK & PLAN

Working architecture — to be validated in Gate 2/3, not yet built

Component	What it does	Built with
Autonomous pentest agents	Reconnaissance → attack planning → verified exploit chains → plain-language fix reports, under **strict per-agent scope assignment** (one target class, one toolset, one budget each). Verification layer before any finding is reported.	Python multi-agent orchestration calling a **pre-defined library of proven security tools** (nmap, Nuclei, ZAP, sqlmap): the tools do the heavy lifting, so AI cost stays at orchestration level.
AI WAF & continuous monitoring	Two-tier detection: recognition of established attack patterns + anomaly scoring for payloads matching no known signature; every decision logged with attack-type classification.	**JEV-family AI decision models** (TypeSafe AI System One class) — typed, calibrated, near-real-time classifiers at a fraction of typical ML/LLM cost; async LLM triage only on escalation; per-tenant rules auto-tuned by agent findings.
Deployment environment	The full stack runs in a **Kali Linux environment on WSL2**, giving the agents native access to the world's most complete open-source security ecosystem — at near-zero license cost, on commodity hardware.	Kali/WSL2 toolset containers; edge reverse proxy; single low-cost container per tenant.
Customer dashboard	Security-posture timeline, readable attack log, monthly posture report. The framework handles onboarding, scoping and reporting — **minimum technical knowledge required**, built for an owner, not an analyst.	Web dashboard + simple API over the event store.
Cost engineering	The core differentiator: making all of the above affordable monthly.	Tool-first agents; JEV-family decisions; **strong LLM response caching** (high cache-hit rates on repeated recon and pattern queries); tiered models.

Three-week plan — what we build and what each week proves

1	Agent prototype that finds seeded vulnerabilities in our own deliberately-vulnerable demo app; interview guide live.	**10–15 structured interviews** with SMB owners (Mom-Test style: past incidents, current workarounds, what they pay today); **3+ pilot LOI conversations** with universities and e-commerce operators.
2	WAF MVP blocking OWASP-class payloads on the demo app; dashboard v1 with classified attack log.	**False-positive benchmark** on known-good traffic; **willingness-to-pay data** from interviews; WAF detection latency measured.
3	Closed loop v1: agent findings tune WAF rules; automated monthly posture report.	**Pilot on a consenting partner**; cost-per-scan and FP-rate numbers published in Gate 2/3; pitch deck with real unit economics.

Known risks, stated plainly: false-positive noise (mitigated by the verification layer and plain-language reporting); agent safety (read-only-first, strict per-agent scope, staging environments); regulation (the PDPA / Cyber Security Act accreditation pathway is a Gate 2 research item); model cost (the tool-first, JEV-and-cache architecture is the bet we will benchmark publicly).

09 SUMMARY & WHAT WE ARE ASKING FOR

One-line summary for the judges

Sri Lanka's online economy is growing at double digits while reported cybercrime multiplies year over year, global data now shows small organizations are the primary targets of AI-accelerated attacks they cannot hire or buy protection against, and the only technology proven to match that speed — autonomous AI — has never been engineered for the businesses that need it most. **We are building for exactly that gap, and Gate 1 proves the gap is real.**

Gate 1 asked us to prove the problem. The evidence above shows it is **local** (99× growth in reported Sri Lankan cybercrime; institutions already breached), **severe** (88% of SMB breaches involve ransomware; one attack closes 1-in-5 SMBs), **accelerating** (AI-generated attacks up ~14× in a year), and **underserved** (no option combines depth, continuity, and affordability). The market is real on both levels: a $78.6B global SMB security category, and a Sri Lankan beachhead of 1M+ businesses newly obligated by the PDPA to protect the data they hold.

Our ask: advance OneEye360 to Gate 2, where we validate the two facts that turn this documented gap into a business — **willingness to pay** (10–15 structured interviews, pilot LOIs) and **our agent's real-world false-positive and cost-per-scan numbers** on test applications. Both are already scheduled in the plan above.

Every number in this write-up is sourced. The companion document — **Supportive Evidence & Source Index** — maps each claim to its source (27 sources), with full URLs, the Sri Lankan incident log, market-size assumptions, and our source-quality methodology.